

Perform Web Application Vulnerability Scanning

Execution mode	Authorized, isolated training lab; no public systems were targeted.
Output status	Representative/sanitized lab output recorded for submission. Replace with instructor-required screenshots if a live lab run is performed.

Aim

Run an automated scan against an authorized web application and classify common weaknesses by risk.

Theory

Automated scanners test discovered parameters with safe assessment payloads and report evidence. The output below is a sanitized ZAP/Nikto training report; it is not a claim about a public application.

Tools and Lab Scope

- OWASP ZAP Active Scan
- Nikto
- DVWA low-security training target

Procedure and Recorded Execution

Step 1. Load the spidered site - Continue with the scoped site map from Experiment 8.

```
target: http://192.168.56.30/dvwa
scope enforced: yes
```

Step 2. Choose a moderate policy - Enable common SQLi, XSS, and header checks with a moderate threshold.

```
policy: baseline-web-medium
attack strength: medium
```

Step 3. Run the active scan - Start the scan and wait for completion within the lab.

```
active scan complete
requests sent: 1,184
alerts: 6
```

Step 4. Cross-check with Nikto - Run the server-side check and compare overlapping issues.

```
nikto: 3 informational findings; no additional high-risk issue
```

Step 5. Export the report - Generate a sanitized HTML/PDF report with affected URLs and remediation.

Vulnerability scan output

The scanner found expected training weaknesses in the intentionally vulnerable application. Findings were validated against the corresponding page behavior before being recorded.

Risk	Finding	Affected area	Suggested fix
High	SQL injection	/vulnerabilities/sqli/?id=1	Parameterized queries; input validation
Medium	Reflected XSS	/search.php?q=	Contextual output encoding; CSP
Low	Missing anti-clickjacking header	Application responses	Set Content-Security-Policy frame-ancestors or X-Frame-Options
Low	Missing CSRF token	Password-change form	Synchronizer token; SameSite cookies
Info	Server banner disclosed	HTTP response headers	Minimize version disclosure

Result

Automated scanning completed and produced a prioritized report. Manual confirmation and safe remediation testing are required before treating any scanner alert as a confirmed production issue.

Safety and Submission Notes

- Scan only owned or approved targets.
- Use low-risk settings first and avoid destructive payloads.
- Confirm alerts manually and record false positives.

Viva Questions and Answers

Spider vs active scan?

Spider discovers routes; active scan sends test payloads to assess behavior.

What is a false positive?

A reported condition that does not represent a real exploitable weakness after verification.

Name three classes checked.

SQL injection, XSS, CSRF, security headers, and outdated components.

Why DVWA low security?

It provides predictable training behavior and reduces complexity for first-time learners.

Why cross-check with Nikto?

Different tools have different coverage and can reduce blind spots.